



Penetration Testing

SHSY (dApp)

Table of Contents

Executive Summary	4
Project Context	4
Penetration Test Scope	7
Security Rating	8
Severity Definitions	9
Status Definitions	10
Penetration Test Findings	11
Conclusion	15
Our Methodology	16
Disclaimers	18
About Hashlock	19

CAUTION

THIS DOCUMENT IS A SECURITY PENETRATION TEST REPORT AND MAY CONTAIN CONFIDENTIAL INFORMATION. THIS INCLUDES IDENTIFIED VULNERABILITIES AND MALICIOUS CODE THAT COULD BE USED TO COMPROMISE THE PROJECT. THIS DOCUMENT SHOULD ONLY BE FOR INTERNAL USE UNTIL ISSUES ARE RESOLVED. ONCE VULNERABILITIES ARE REMEDIATED, THIS REPORT CAN BE MADE PUBLIC. THE CONTENT OF THIS REPORT IS OWNED BY HASHLOCK PTY LTD FOR THE USE OF THE CLIENT.

Executive Summary

The SHSY team partnered with Hashlock to conduct a security Penetration Test of their SHSY Project code base. Hashlock manually and proactively reviewed the code to ensure the project's team and community that the deployed tools were secure.

Project Context

SHSY is a decentralized financial entertainment token integrating financial innovation with entertainment, including puzzle games, prediction games, and social interaction, within a diverse blockchain ecosystem. SHSY is not registered as a security in the United States and does not promise investment returns. The cryptocurrency market is highly volatile, and participation may result in financial losses. Users must independently assess all risks and consult professional financial, legal, or investment advisors. The Uncle Alliance Team is not responsible for any financial consequences.

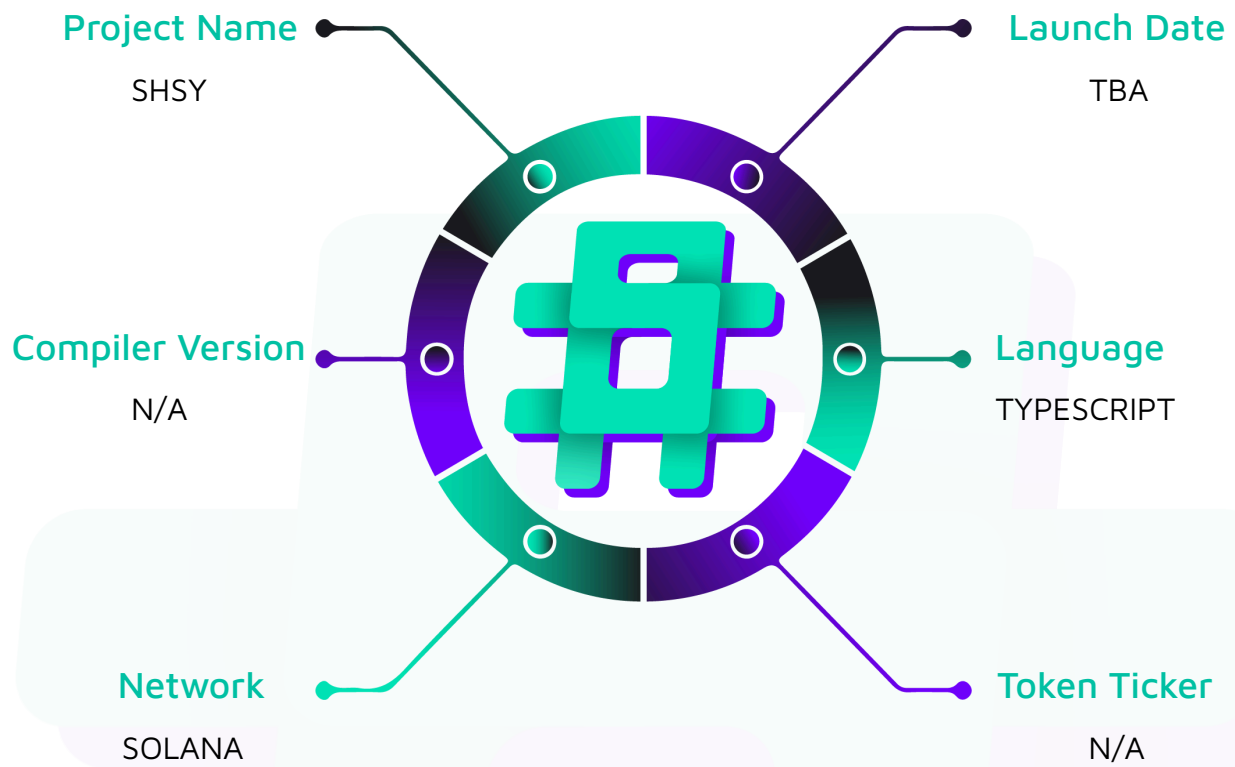
Project Name: SHSY

Project Type: dApp

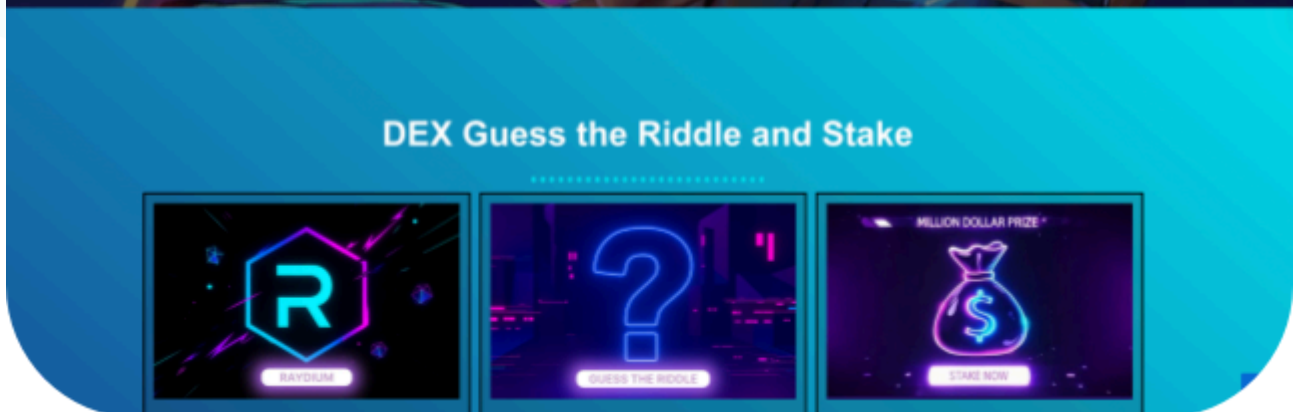
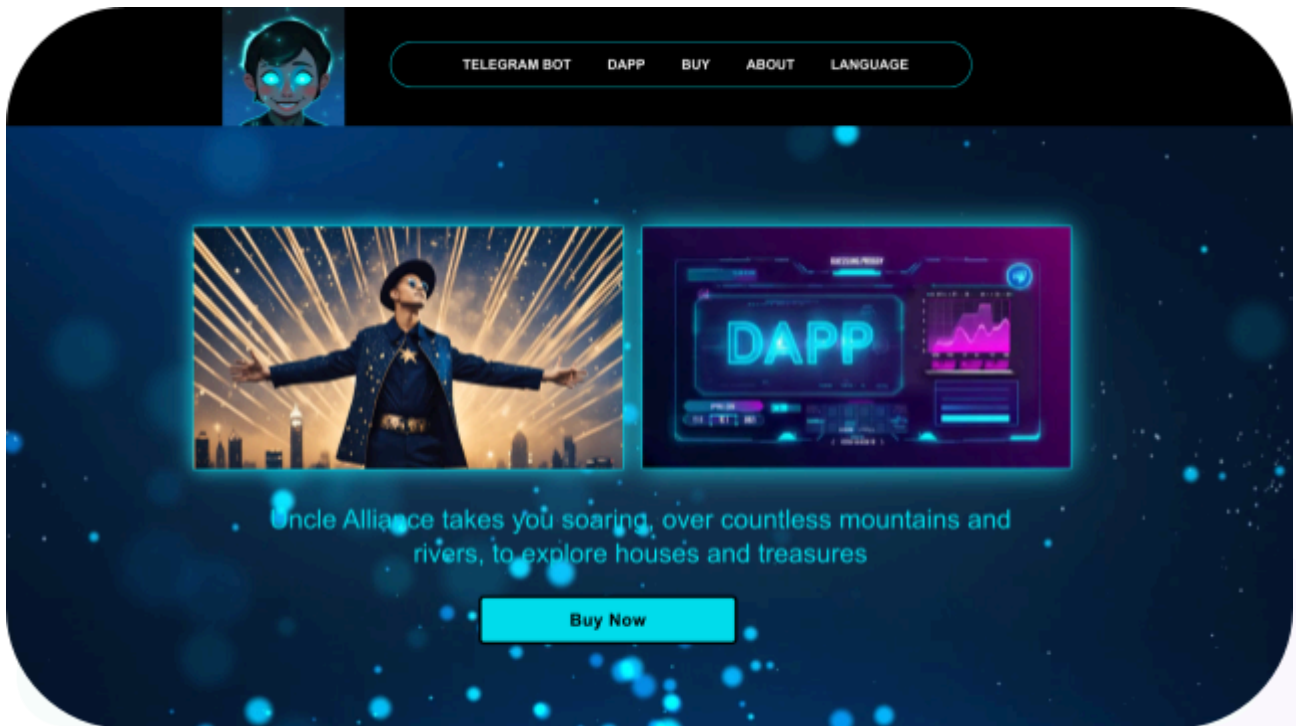
Website: <https://shsycoin.com/>

Logo:



Visualised Context:

Project Visuals:



Penetration Test Scope

At Hashlock, we executed a comprehensive penetration test on the SHSY project. Our scope included a detailed security assessment, where we rigorously examined the code to identify vulnerabilities and assess overall efficiency. The testing process involved a meticulous manual review, supplemented by advanced software-assisted techniques, to ensure thorough analysis and accuracy.

Description	SHSY Project Code Base
Platform	Web apps & APIs
Penetration Test Date	August, 2025
Repository/Website URL/IP Tested	Zip file

Security Rating

After Hashlock's Penetration Test, we found the code base to be **"Secure"**. The code follows simple logic, with correct and detailed ordering.



Not Secure

Vulnerable

Secure

Hashlocked

The 'Hashlocked' rating is reserved for projects that ensure ongoing security via bug bounty programs or on-chain monitoring technology.

All issues uncovered during automated and manual analysis were meticulously reviewed and applicable vulnerabilities are presented in the [Penetration Test Findings](#) section.

All vulnerabilities initially identified have now been resolved and acknowledged.

Hashlock found:

1 High-severity vulnerabilities

1 Medium-severity vulnerabilities

3 Low-severity vulnerabilities

Caution: Hashlock's Penetration Tests do not guarantee a project's success or ethics, and are not liable or responsible for security. Always conduct independent research about any project before interacting.

Severity Definitions

The severity levels assigned to findings represent a comprehensive evaluation of both their potential impact and the likelihood of occurrence within the system. These categorizations are established based on Hashlock's professional standards and expertise, incorporating both industry best practices and our discretion as security auditors. This ensures a tailored assessment that reflects the specific context and risk profile of each finding.

Significance	Description
High	High-severity vulnerabilities can result in loss of funds, asset loss, access denial, and other critical issues that will result in the direct loss of funds and control by the owners and community.
Medium	Medium-level difficulties should be solved before deployment, but won't result in loss of funds.
Low	Low-level vulnerabilities are areas that lack best practices that may cause small complications in the future.
Gas	Gas Optimisations, issues, and inefficiencies
QA	Quality Assurance (QA) findings are purely informational and don't impact functionality. These notes help clients improve the clarity, maintainability, or overall structure of the code, ensuring a cleaner and more efficient project. They should be addressed for optimization but are not critical to the system's performance or security.

Status Definitions

Each identified security finding is assigned a status that reflects its current stage of remediation or acknowledgment. The status provides clarity on the handling of the issue and ensures transparency in the auditing process. The statuses are as follows:

Significance	Description
Resolved	The identified vulnerability has been fully mitigated either through the implementation of the recommended solution proposed by Hashlock or through an alternative client-provided solution that demonstrably addresses the issue
Acknowledged	The client has formally recognized the vulnerability but has chosen not to address it due to the high cost or complexity of remediation. This status is acceptable for medium and low-severity findings after internal review and agreement. However, all high-severity findings must be resolved without exception.
Unresolved	The finding remains neither remediated nor formally acknowledged by the client, leaving the vulnerability unaddressed.

Penetration Test Findings

High

[H-01] API - Admin endpoints lack authentication, allowing unauthorized control over the platform

Description

All administrative API endpoints located under the `/api/admin/` path are publicly exposed without any authentication or authorization checks, as seen in server/[index.ts](#).

```
// File: server/index.ts

app.post("/api/dapp/withdraw", async (req, res) => {

  try {

    const { walletAddress, id, amount, signature } = req.body;

    // ...

    const transactionData =

      await simplifiedMultipleStaking.createWithdrawTransaction(

        walletAddr
```

Impact

Any user can invoke administrative functions, leading to complete platform takeover and theft of funds.

Recommendation

Implement a mandatory, signature-based authentication middleware for all `/api/admin/*` routes to verify the caller is a designated administrator.

Status

Resolved

Medium

[M-01] API - Lack of rate limiting

Description

The Express application setup in server/index.ts lacks any rate-limiting middleware, allowing an unlimited number of requests from a single source.

Impact

As a result, the platform is vulnerable to application-level Denial-of-Service attacks, brute-forcing of trivia answers, and resource exhaustion.

Recommendation

Implement IP-based rate limiting across all API endpoints, with stricter rules for sensitive actions like submissions and transaction creation.

Status

Resolved

Low

[L-01] API - Admin-controlled riddle content can lead to stored cross-site scripting

Description

The POST /api/admin/riddles endpoint in server/index.ts directly saves content from the request body into the database via storage.createRiddle. This data is later rendered on the frontend without evidence of sanitization, creating a Stored XSS vector.

However, this is only exploitable from an admin standpoint. As a result, An attacker with admin access can inject malicious JavaScript payloads that execute in the browsers of all users, enabling session hijacking and data theft.

Recommendation

Implement strict output encoding for all user-supplied content before it is rendered on the frontend. All special characters should be HTML encoded.

Status

Resolved

[L-02] API - Missing security headers

Description

The POST `/api/admin/riddles/batch-upload` endpoint, as documented in the README, accepts CSV file uploads. The corresponding backend code in `server/index.ts` processes a JSON array but lacks any validation of the content within the array elements before creating database entries.

Recommendation

Implement strict output encoding for all user-supplied content before it is rendered on the frontend. All special characters should be HTML encoded.

Status

Resolved

[L-03] API - Insecure Math library

Description

The `processCompletedChallenge` function in `server/simple-global-challenges.ts` uses the non-cryptographic `Math.random()` to shuffle participants and select winners. This method is known to be biased and is not suitable for security-sensitive operations.

Recommendation

Replace the insecure shuffling algorithm with a cryptographically secure random number generator, such as the one provided by Node.js's built-in `crypto` module.

Status

Resolved

Conclusion

After Hashlock's analysis, the SHSY project seems to have a sound and well-tested code base, now that our vulnerability findings have been resolved and acknowledged. Overall, most of the code is correctly ordered and follows industry best practices. The code is well commented on as well. To the best of our ability, Hashlock is not able to identify any further vulnerabilities.

Our Methodology

Hashlock strives to maintain a transparent working process and to make our Penetration Tests a collaborative effort. The objective of our security Penetration Tests is to improve the quality of systems and upcoming projects we review and to aim for sufficient remediation to help protect users and project leaders. Below is the methodology we use in our security Penetration Test process.

Manual Code Review:

In manually analysing all of the code, we seek to find any potential issues with code logic, error handling, protocol and header parsing, cryptographic errors, and random number generators. We also watch for areas where more defensive programming could reduce the risk of future mistakes and speed up future Penetration Tests. Although our primary focus is on the in-scope code, we examine dependency code and behavior when it is relevant to a particular line of investigation.

Vulnerability Analysis:

Our methodologies include manual code analysis, user interface interaction, and white box penetration testing. We consider the project's website, specifications, and whitepaper (if available) to attain a high-level understanding of what functionality the code base under review contains. We then communicate with the developers and founders to gain insight into their vision for the project. We install and deploy the relevant software, exploring the user interactions and roles. While we do this, we brainstorm threat models and attack surfaces. We read design documentation, review other Penetration Test results, search for similar projects, examine source code dependencies, skim open issue tickets, and generally investigate details other than the implementation.

Documenting Results:

We undergo a robust, transparent process for analysing potential security vulnerabilities and seeing them through to successful remediation. When a potential issue is discovered, we immediately create an issue entry for it in this document, even though we still need to verify the feasibility and impact of the issue. This process is vast because we document our suspicions early even if they are later shown not to represent exploitable vulnerabilities. We generally follow a process of first documenting the suspicion with unresolved questions, and then confirming the issue through code analysis, live experimentation, or automated tests. Code analysis is the most tentative, and we strive to provide test code, log captures, or screenshots demonstrating our confirmation. After this, we analyse the feasibility of an attack in a live system.

Suggested Solutions:

We search for immediate mitigations that live deployments can take and finally, we suggest the requirements for remediation engineering for future releases. The mitigation and remediation recommendations should be scrutinised by the developers and deployment engineers, and successful mitigation and remediation is an ongoing collaborative process after we deliver our report, and before the contract details are made public.

Disclaimers

Hashlock's Disclaimer

Hashlock's team has analysed the code bases in accordance with the best industry practices at the date of this report, in relation to: cybersecurity vulnerabilities and issues in the code base source code, the details of which are disclosed in this report, (Source Code); the Source Code compilation, deployment, and functionality (performing the intended functions).

Due to the fact that the total number of test cases is unlimited, the Penetration Test makes no statements or warranties on the security of the code. It also cannot be considered a sufficient assessment regarding the utility and safety of the code, bug-free status, or any other statements of the contract. While we have done our best in conducting the analysis and producing this report, it is important to note that you should not rely on this report only. We also suggest conducting a bug bounty program to confirm the high level of security of this code base.

Hashlock is not responsible for the safety of any funds and is not in any way liable for the security of the project.

Technical Disclaimer

Code is deployed and executed on a platform. The platform, its programming language, and other software related to the code base can have their own vulnerabilities that can lead to attacks. Thus, the Penetration Test can't guarantee the explicit security of the Penetration Tested code bases.

About Hashlock

Hashlock is an Australian-based company aiming to help facilitate the successful widespread adoption of distributed ledger technology. Our key services all have a focus on security, as well as projects that focus on streamlined adoption in the business sector.

Hashlock is excited to continue to grow its partnerships with developers and other web3-oriented companies to collaborate on secure innovation, helping businesses and decentralised entities alike.

Website: hashlock.com.au

Contact: info@hashlock.com.au



#hashlock.